

Membership Inference Attacks on ML Models

Privacy Auditing and GDPR Implications

Jonathan Ted Benson Cerullo Uyi

`jonathan.cerullouyi@studio.unibo.it`

Matricola: 0001164850

University of Bologna — MSc in Artificial Intelligence

Course: Ethics in Artificial Intelligence

June 2026

Abstract

Machine learning models trained on personal data may unintentionally *memorise* information about individual training records, exposing data subjects to a class of privacy attacks known as *Membership Inference Attacks* (MIA). This project implements an empirical privacy-auditing pipeline for image classifiers and uses it to quantify the privacy/utility trade-off of two defense families: informal regularisation (L2, dropout, early stopping) and formal guarantees provided by Differentially Private Stochastic Gradient Descent (DP-SGD). Five model configurations are trained on CIFAR-10 and attacked with two MIA strategies of increasing sophistication (threshold-based and shadow-model). The results are then mapped to specific articles of the General Data Protection Regulation — in particular Articles 5, 6, 17, and 32 — to assess what “appropriate technical measures” for ML systems may concretely look like under the regulation. We find that informal regularisation mitigates but does not eliminate privacy leakage (shadow attack $\text{AUC} = 0.66$), whereas DP-SGD reduces attack success to near-random across the tested privacy budgets ($\text{AUC} \approx 0.51$ for $\varepsilon \in \{1, 5, 10\}$), at the cost of a substantial drop in classification accuracy. We argue that these findings make the *measurable* dimension of GDPR compliance for ML systems explicit and offer practitioners a way to operationalise risk-based decision-making.

Keywords: membership inference attacks, differential privacy, GDPR, privacy auditing, DP-SGD, machine learning ethics.

Contents

1	Introduction	4
2	Background	5
2.1	Membership Inference Attacks	5
2.2	Differential Privacy and DP-SGD	5
2.3	GDPR Fundamentals	6
3	Methodology	7
3.1	Threat Model	7
3.2	Attacks	7
3.3	Defenses	8
3.4	Dataset and Splits	9
3.5	Evaluation Metrics	9
4	Experimental Setup	10
4.1	Architecture	10
4.2	Training Configurations	10
4.3	Reproducibility	11
4.4	Software Stack	11
5	Results	11
5.1	Experiment 1: Overfitted Baseline	11
5.2	Experiment 2: Regularised Model	11
5.3	Experiments 3–5: DP-SGD Sweep	12
5.4	Aggregate Comparison	12
5.5	Privacy–Utility Trade-off	12
6	GDPR Analysis	13
6.1	Article 5 — Principles relating to processing	14
6.2	Article 6 — Lawfulness of processing	15
6.3	Article 17 — Right to erasure	16
6.4	Article 32 — Security of processing	17
7	Discussion	17
7.1	Findings, restated	17
7.2	Practitioner Recommendations	18
7.3	What “compliance” does and does not mean here	18
8	Limitations and Future Work	19
9	Conclusions	19

1 Introduction

Machine learning systems are increasingly deployed on data that, under European law, qualifies as “personal data” (GDPR Art. 4(1)) — from medical images and biometric identifiers to consumer behaviour records and demographic information. The standard intuition that a trained model is “just numbers” and therefore privacy-preserving by construction is empirically false: trained models leak information about their training data, and this leakage is measurable.

The most studied form of such leakage is the *Membership Inference Attack* (MIA), introduced in its modern form by Shokri et al. [1] and refined by subsequent work [2, 3]. Given black-box query access to a trained model, an adversary attempts to determine whether a given record was part of the training set or not. A successful MIA does not, by itself, recover the record’s contents — but it tells the attacker that the record exists in the training corpus, which is sufficient to violate confidentiality in many real-world contexts (a hospital’s training set, for instance, may already *define* a sensitive attribute by virtue of its collection criteria).

This project pursues two parallel goals. The first is technical: build a reproducible privacy-auditing pipeline that quantifies MIA vulnerability across realistic defense configurations, including the formal guarantees of Differentially Private Stochastic Gradient Descent (DP-SGD) [4]. The second is normative: take the empirical numbers and use them to interrogate what “appropriate technical and organisational measures” (GDPR Art. 32) should mean when the controller is, in fact, training a deep neural network. The project deliberately avoids the temptation of simply declaring “DP-SGD makes you compliant” — an answer which, as we argue in Section 6, is both legally inaccurate and technically misleading.

Contributions. The contributions of this project are:

1. A reproducible Jupyter implementation of two MIA strategies (threshold-based, shadow-model) and two defense families (regularisation, DP-SGD with $\epsilon \in \{1, 5, 10\}$), evaluated on CIFAR-10 with a methodologically clean experimental setup (Section 4).
2. Empirical evidence that regularisation alone is insufficient to prevent MIA, while DP-SGD effectively neutralises both attacks at all tested privacy budgets — but at a substantial utility cost (Section 5).
3. A mapping of these results to GDPR Articles 5, 6, 17, and 32, with concrete (and falsifiable) practitioner recommendations (Section 6).

Roadmap. Section 2 provides the technical and legal background. Section 3 describes the threat model, attack and defense designs, and the dataset choice. Section 4 fixes the experimental setup. Section 5 reports and discusses the results, supported by the figures generated by the experiments. Section 6 maps the empirical findings to GDPR provisions. Section 7 consolidates the practitioner-facing implications. Section 8 is candid about what the project does *not* cover, and Section 9 concludes.

2 Background

2.1 Membership Inference Attacks

Threat model. An MIA adversary aims to infer, given black-box query access to a trained classifier f_θ and a candidate input x , whether x was part of the training set D used to fit θ . The attack outcome is binary — “member” or “non-member” — but, like any binary classifier, it can be evaluated along the full range of operating points by means of a Receiver Operating Characteristic (ROC) curve.

The intuition behind why MIA works is straightforward and was made precise by Yeom et al. [2]: a model that has overfit its training data tends to produce systematically more confident (and correct) predictions on training samples than on samples drawn from the same distribution but *not* seen during training. The generalisation gap of a model is therefore not just a property of interest to ML practitioners — it is also, per Yeom et al., a privacy-relevant quantity.

Attack families. A useful taxonomy of MIA strategies, in order of increasing sophistication, is the following:

- **Threshold-based attacks.** Use a single per-sample statistic (typically the cross-entropy loss, or the model’s confidence on the correct class) and threshold it. A sample with a low loss is classified as “member”. The attack of Yeom et al. [2] is the canonical example.
- **Shadow-model attacks.** Train multiple “shadow” models on data drawn from the same distribution as the target but disjoint from the target’s training set. For each shadow model, observe the per-sample model behaviour (loss, confidence, entropy, etc.) on *its own* members and non-members; this generates a labelled dataset of “member-like” versus “non-member-like” feature vectors. A meta-classifier (e.g., a gradient-boosting model) is then trained on these features and applied to the target model’s outputs to predict membership of any given query sample [1].
- **Likelihood-ratio (first-principles) attacks.** The Carlini et al. [3] family of attacks treats MIA as a hypothesis-testing problem and is designed to achieve high True Positive Rate at very low False Positive Rate — the regime that matters for real-world privacy auditing. We use these as a reference (in particular for the choice of evaluation metrics) but do not implement them in this work; they are listed under future work.

Why TPR @ low FPR. A point that is now broadly accepted in the privacy literature, following Carlini et al., is that aggregate metrics such as accuracy or AUC can paint an over-optimistic picture of an attack’s harmlessness. A real adversary does not run the attack at the median operating point; they run it at the operating point which gives them the highest True Positive Rate while keeping False Positive Rate below some tolerance (e.g., 1% or 0.1%). We therefore report TPR@1%FPR and TPR@0.1%FPR alongside AUC.

2.2 Differential Privacy and DP-SGD

Definition. A randomised algorithm $\mathcal{A}$ is (ϵ, δ) -*differentially private* if, for any pair of neighbouring datasets D, D' (differing on a single record) and any measurable subset S of the output space,

$$\Pr[\mathcal{A}(D) \in S] \leq e^\epsilon \cdot \Pr[\mathcal{A}(D') \in S] + \delta. \quad (1)$$

The parameter ε is the *privacy budget*: smaller values correspond to stronger privacy. The parameter δ is the failure probability of the guarantee — conventionally chosen to be cryptographically small, e.g., $\delta = 10^{-5}$ when $|D| = 10^4$ [6].

The crucial property of differential privacy is that the guarantee holds against *any* adversary, regardless of their auxiliary knowledge. In particular, an MIA adversary is, by definition, a specific case of such an adversary; therefore (ε, δ) -DP provides a quantitative *upper bound* on the success of any membership inference attack.

DP-SGD. The training-time mechanism that has emerged as the practical workhorse of differentially private deep learning is DP-SGD, introduced by Abadi et al. [4]. Its two ingredients are:

1. **Per-sample gradient clipping:** in each minibatch, the gradient with respect to each individual sample is clipped to a fixed ℓ_2 norm C . This bounds the influence that any single record can have on a parameter update.
2. **Calibrated Gaussian noise:** noise sampled from $\mathcal{N}(0, \sigma^2 C^2 \mathbf{I})$ is added to the sum of clipped per-sample gradients before the SGD update. The noise multiplier σ governs the privacy budget consumed per step; the cumulative budget across training is tracked with a privacy accountant (we use the Rényi-DP accountant [7] as implemented in Opacus [9]).

A subtle but practically important point is that DP-SGD requires *Poisson subsampling* (or an analogous batch-construction step) to amplify privacy via subsampling. Off-the-shelf libraries handle this automatically when their public API is used as intended; for instance, Opacus’s `make_private_with_epsilon` replaces the provided `DataLoader` with a Poisson-subsampled one and configures the noise multiplier so that the cumulative ε at the end of training matches a target value.

Privacy versus utility. DP-SGD comes at a cost. The clipping bounds the gradient signal that can be exploited by training (potentially limiting the model’s ability to fit complex patterns) and the noise injection introduces variance that the optimisation must average away. Tramèr and Boneh [5] showed that under DP-SGD, deep learning’s usual “representation learning” benefits collapse and that linear models on hand-crafted features sometimes outperform end-to-end DP-SGD networks — a finding that we re-encounter, in mild form, in our own DP results (Section 5).

2.3 GDPR Fundamentals

The General Data Protection Regulation (Regulation (EU) 2016/679 [12]) imposes obligations on controllers and processors of personal data of individuals in the EU. The provisions most directly relevant to ML systems trained on personal data are:

Article 5 enumerates the principles of processing. Of particular relevance here: *lawfulness, fairness and transparency* (5(1)(a)), *purpose limitation* (5(1)(b)), *data minimisation* (5(1)(c)), *accuracy* (5(1)(d)), *storage limitation* (5(1)(e)), and *integrity and confidentiality* (5(1)(f)). Article 5(2) places the burden of demonstrating compliance on the controller (*accountability*).

Article 6 enumerates the lawful bases for processing. Processing is lawful only if at least one applies: consent (a), contract (b), legal obligation (c), vital interests (d), public interest

/ official authority (e), or legitimate interest (f). The latter, in particular, is subject to a balancing test against data subjects’ rights and reasonable expectations.

Article 9 establishes the special regime for sensitive data (“special categories of personal data”): racial or ethnic origin, political opinions, religious or philosophical beliefs, trade union membership, genetic data, biometric data for unique identification, health data, and data concerning sex life or sexual orientation. Processing of these categories is prohibited unless one of the narrow exceptions in 9(2) applies.

Article 17 grants data subjects the right to erasure (the “right to be forgotten”) subject to certain limitations and balancing factors.

Article 32 requires controllers to implement “*appropriate technical and organisational measures*” to ensure a level of security *appropriate to the risk* — explicitly mentioning, at 32(1)(a), the pseudonymisation and encryption of personal data. The proportionality of measures is to be assessed against the “state of the art”.

A point that is occasionally lost in the technical literature is that the GDPR is *risk-based*, not *rule-based*. The standard set by Article 32 is not a fixed checklist; it is a moving target that shifts as the state of the art shifts. As privacy attacks against ML models become more capable, the bar for “appropriate” measures correspondingly rises — which is precisely why this kind of empirical privacy auditing is not just academic.

3 Methodology

3.1 Threat Model

The adversary considered in this work has the following capabilities:

- **Black-box query access** to the target classifier f_θ . The adversary can submit arbitrary inputs and receive the model’s output (we assume the full softmax vector is returned, which is the most permissive black-box setting; a label-only setting would weaken the attacks).
- **Knowledge of the data distribution.** The adversary knows the data distribution $\mathcal{D}$ from which the training set was drawn and can sample from it. This enables the construction of shadow models on disjoint data.
- **No knowledge of the model architecture, weights, or training hyper-parameters.** The shadow-model attack assumes only that the adversary can train models of comparable capacity on the same task.

This is the standard MIA threat model used by Shokri et al. [1]. Stronger threat models exist (white-box access, gradient access during training), but they are not necessary to demonstrate the privacy risk: black-box MIA is already feasible.

3.2 Attacks

Threshold attack. The simpler of the two attacks implemented in this work is a per-sample loss threshold attack (Yeom et al. [2]). Algorithm 1 sketches the procedure: the adversary computes the cross-entropy loss of the target model on each candidate input, with sign reversed

Algorithm 1 Threshold-based MIA (Yeom et al. [2])

Require: Target model f_θ , sets of candidate inputs D_m (members) and D_{nm} (non-members)
Ensure: Per-sample membership scores

- 1: **for** each $(x, y) \in D_m \cup D_{nm}$ **do**
- 2: $\ell(x, y) \leftarrow -\log f_\theta(x)_y$ $\triangleright$ cross-entropy loss
- 3: $s(x, y) \leftarrow -\ell(x, y)$ $\triangleright$ higher s = more member-like
- 4: **end for**
- 5: Evaluate $\{s(x, y)\}$ against ground-truth labels (member / non-member) by AUC, TPR@1%FPR, TPR@0.1%FPR.

Algorithm 2 Shadow-model MIA (Shokri et al. [1])

Require: Target f_θ , shadow data pools $D_{sh,in}$ and $D_{sh,out}$ disjoint from the target’s training set; number of shadows K

- 1: Initialise meta-training set $\mathcal{M} \leftarrow \emptyset$
- 2: **for** $k = 1, \dots, K$ **do**
- 3: Sample $D_{in}^{(k)}, D_{out}^{(k)}$ from $D_{sh,in}, D_{sh,out}$
- 4: Train shadow model $g^{(k)}$ on $D_{in}^{(k)}$
- 5: **for** each $(x, y) \in D_{in}^{(k)} \cup D_{out}^{(k)}$ **do**
- 6: Compute features $\phi(g^{(k)}, x, y)$ $\triangleright$ loss, confidences, entropy, etc.
- 7: Add $(\phi, \mathbb{I}[(x, y) \in D_{in}^{(k)}])$ to $\mathcal{M}$
- 8: **end for**
- 9: **end for**
- 10: Train meta-classifier h on $\mathcal{M}$
- 11: **for** each candidate (x, y) **do**
- 12: $s(x, y) \leftarrow h(\phi(f_\theta, x, y))$
- 13: **end for**
- 14: Evaluate $\{s(x, y)\}$ as in Algorithm 1.

so that “low loss” translates to “high score”; the resulting scores are then evaluated against the ground-truth membership labels with standard binary-classification metrics.

Shadow-model attack. The shadow-model attack (Algorithm 2) is the more powerful of the two. The key methodological requirement — and a frequent source of bias in under-careful implementations — is that the data used to train the shadow models must be *disjoint* from the target’s training set. Otherwise, the meta-classifier learns a biased representation of “member-like” that can either over- or under-estimate the attack’s true effectiveness on the target.

Per-sample features. The shadow-model meta-classifier is trained on a six-dimensional feature vector per sample, capturing both classical and privacy-relevant statistics of the model’s output distribution: maximum confidence, correct-class confidence, entropy, cross-entropy loss (raw and log-scale), and confidence gap (the difference between the top-2 predicted probabilities). The meta-classifier itself is a gradient-boosting ensemble (100 trees, depth 3), chosen for its robustness on small heterogeneous tabular inputs.

3.3 Defenses

We compare two defense families, deliberately chosen to span the spectrum from “what every ML engineer already does for generalisation” to “what only privacy-aware engineers do for privacy by

construction”.

Informal defenses (regularisation). L2 weight decay ($\lambda = 10^{-3}$), dropout ($p = 0.5$), and validation-based early stopping (patience 10 epochs, max 100 epochs). These are standard ML hygiene; they reduce overfitting and therefore plausibly reduce membership leakage as a side effect, but they offer *no formal privacy guarantee*.

Formal defenses (DP-SGD). DP-SGD via Opacus, with per-sample gradient clipping at $C = 1.2$ and $\delta = 10^{-5}$, swept over three target privacy budgets $\varepsilon \in \{1, 5, 10\}$. The budget $\varepsilon = 10$ is on the lax end but still provides a meaningful guarantee against MIA (as we show in Section 5); $\varepsilon = 1$ is on the strict end and approaches the regime where utility collapses on small datasets [5].

3.4 Dataset and Splits

Choice of CIFAR-10. We use CIFAR-10 [8] (60,000 32×32 colour images across 10 object classes) as a controlled benchmark. CIFAR-10 itself contains object categories rather than personal data, and we are explicit about this trade-off: the GDPR connection is established at the level of the *architecture and training procedure*, not at the level of specific individuals depicted in the dataset. The privacy implications of MIA on a CNN classifier of CIFAR-10 transfer *directly* to MIA on a CNN classifier of, e.g., CheXpert [11] chest X-rays, ISIC dermatoscopic images, or face-recognition embeddings; only the input distribution changes. CIFAR-10 is the de facto MIA benchmark in the literature (used in [1, 3]) precisely because the mechanism we study — gradient memorisation under overfitting — is dataset-independent.

Split design. A central methodological requirement is that the data pools used by the target, the shadow models, and the DP-SGD experiments be *mutually disjoint* where it matters. In particular:

- The shadow-model meta-classifier must not be trained on data that overlaps with the target’s training set; otherwise the meta-features it learns are not those of a true black-box attacker.
- The early-stopping validation set used by the regularised defense must not overlap with the target’s training set; otherwise the “member set” used by the attack contains samples the model never actually trained on, biasing both the generalisation gap and the attack metrics.
- The DP-SGD training pool must be larger than the target members (because DP-SGD requires sufficient data to overcome the noise) but must *include* the target members, so that the attack actually probes membership of records that the model genuinely trained on.

Table 1 summarises the resulting six disjoint pools. Both the disjointness and the inclusion of the target members in the DP pool are enforced as runtime assertions in the experimental code.

3.5 Evaluation Metrics

For each experiment, we report:

- **Generalisation gap:** train accuracy minus test accuracy on `target_train` and `target_test`. This is a privacy-relevant signal in its own right (Yeom et al.) but is not, on its own, a sufficient privacy indicator.

Table 1: Data pools used in the experiments. Pools are mutually disjoint, except that the DP training pool deliberately *includes* the target training pool so that the 2,500 target members are also genuine members of the DP-trained models.

Pool	Size	Role
target_train	2,500	Members of the target classifier (Exp. 1, 2). Also a subset of the DP training pool.
target_test	2,500	Held-out non-members. Drawn from the CIFAR-10 test split.
shadow_train	5,000	Members for the shadow models.
shadow_test	2,500	Non-members for the shadow models.
reg_val	500	Validation set for early-stopping (Exp. 2).
dp_train	15,000	Training pool for DP-SGD (Exp. 3–5). Includes <code>target_train</code> ; disjoint from the other pools.

- **Attack AUC:** Area under the ROC curve of the attack, computed over the union of members and non-members, balanced 50/50.
- **TPR@1%FPR and TPR@0.1%FPR:** True Positive Rate at low False Positive Rate, computed by linear interpolation on the empirical ROC curve. These are the privacy-relevant operating points: a real adversary will accept very few false positives in exchange for a high true-positive rate on the records they do flag.
- For DP-SGD experiments, the *actual* ϵ achieved at the end of training (as reported by the Rényi-DP accountant), which can differ slightly from the target ϵ passed to Opacus.

A model is privacy-leaking if and only if the attack AUC is significantly above 0.5 *and* the low-FPR TPRs are significantly above the corresponding chance levels (i.e., 0.01 and 0.001, respectively).

4 Experimental Setup

4.1 Architecture

We use a small CNN with two convolutional blocks (each containing two convolutional layers and one max-pooling layer) followed by a fully connected classifier (256 hidden units, dropout, 10-way softmax). The total parameter count is approximately 1.05M. The architecture is deliberately simple: the goal is not to set a state-of-the-art accuracy on CIFAR-10 but to obtain a model that overfits the small target training set (2,500 samples) under the no-defense baseline, so that MIA is empirically meaningful.

4.2 Training Configurations

Five configurations are evaluated, all on the same target/non-member split for direct comparability:

1. **Exp. 1 — Overfitted (worst case).** 150 epochs of Adam at learning rate 10^{-3} , no weight decay, no dropout. Establishes the upper bound of privacy leakage.
2. **Exp. 2 — Regularised (informal defense).** L2 weight decay 10^{-3} , dropout $p = 0.5$ in the classifier head, early stopping on a disjoint validation set (`reg_val`, 500 samples) with patience 10, maximum 100 epochs.

3. **Exp. 3 — DP-SGD with $\varepsilon = 10$.** 60 epochs of DP-Adam (learning rate 2×10^{-3} , max gradient norm $C = 1.2$, $\delta = 10^{-5}$) on `dp_train` (15,000 samples).
4. **Exp. 4 — DP-SGD with $\varepsilon = 5$.** Same as Exp. 3 with a tighter privacy budget.
5. **Exp. 5 — DP-SGD with $\varepsilon = 1$.** Same as Exp. 3 with the strictest privacy budget tested, approaching the regime where utility collapses for small CNNs.

For all five configurations, the shadow attack uses $K = 4$ shadow models, each trained for 100 epochs on a disjoint 1,250 + 1,250 in/out split sampled from the shadow pools.

4.3 Reproducibility

All randomness is seeded (`SEED = 42`): NumPy, PyTorch CPU, PyTorch CUDA, and the cuDNN backend (with `cudnn.deterministic = True` and `cudnn.benchmark = False`). The data pools are constructed once from a fixed permutation of the CIFAR-10 indices, with runtime assertions enforcing pairwise disjointness and the target-subset property of the DP pool. The full training run is observed to produce numerically very close results across seeds; the qualitative findings (Section 5) are robust.

4.4 Software Stack

The implementation uses PyTorch 2.x for model training, Opacus 1.x for DP-SGD, scikit-learn for the gradient-boosting meta-classifier, and Hugging Face Datasets for CIFAR-10 access. Hyperparameter choices, including the noise multipliers used by DP-SGD, are computed automatically by Opacus given the target (ε, δ) and the training schedule, so that the reported ε values correspond to actual privacy spent at the end of training, as opposed to nominal budgets only.

5 Results

5.1 Experiment 1: Overfitted Baseline

The overfitted target reaches train accuracy 99.6% and test accuracy 60.1%, with a generalisation gap of 39.5 percentage points after 150 epochs of unregularised training — the expected worst-case behaviour of a small CNN on a 2,500-sample training set.

The threshold attack achieves $AUC = 0.791$ with $TPR@1\%FPR = 0.021$ and $TPR@0.1\%FPR = 0.002$. The shadow-model attack achieves $AUC = 0.788$ with $TPR@1\%FPR = 0.033$ and $TPR@0.1\%FPR = 0.009$. Both attacks comfortably exceed the random baseline of 0.5, and the $TPR@1\%FPR$ values are several times their chance level of 0.01. The shadow attack outperforms the threshold attack on the low-FPR metric (**0.033 vs. 0.021**, a 57% improvement), confirming that learning a meta-classifier over a richer per-sample feature set extracts privacy signal that a simple loss-threshold rule misses.

5.2 Experiment 2: Regularised Model

With L2, dropout, and early stopping in place, the regularised target reaches train accuracy 88.6% and test accuracy 62.2%, with a generalisation gap of 26.4 percentage points. Notably, the regularised model has *higher* test accuracy than the overfitted one (62.2% vs. 60.1%): regularisation

does its intended job of improving generalisation. Equally notably, the generalisation gap remains substantial — regularisation reduces but does not eliminate it.

The threshold attack achieves $AUC = 0.668$ and the shadow-model attack $AUC = 0.664$. Both attacks remain comfortably above the random baseline; the privacy leak is reduced by approximately 15% in absolute AUC compared to the overfitted target, but the model is still demonstrably leaking membership information. $TPR@1\%FPR$ drops from 0.033 to 0.020, a useful but modest mitigation.

The headline conclusion of this experiment is the cleanest in the project: *regularisation is a defense for generalisation, not a defense for privacy*. The two phenomena are correlated — and the correlation is unmistakable in the absolute numbers — but they are not the same phenomenon.

5.3 Experiments 3–5: DP-SGD Sweep

The three DP-SGD configurations behave qualitatively as Differential Privacy theory predicts: the noise injection enforces an upper bound on the influence of any single record on the trained weights, and both attacks are correspondingly forced to near-random performance across all three privacy budgets.

Specifically, $\varepsilon = 10$ yields $AUC = 0.511$ (threshold) and $AUC = 0.511$ (shadow), with $TPR@1\%FPR$ in the range of 0.008–0.009 — statistically indistinguishable from chance. The same pattern holds at $\varepsilon = 5$ ($AUC \approx 0.512$) and at $\varepsilon = 1$ ($AUC \approx 0.511$). Three observations follow from this:

1. DP-SGD provides effective privacy protection *at the looser end of the privacy budget spectrum*, not just at the strict end. Even $\varepsilon = 10$ — which would be considered a generous budget by most DP practitioners — already nullifies the attacks tested here.
2. There is, accordingly, *no marginal privacy benefit* from tightening ε from 10 to 1 in this setup. Tightening ε buys protection against *stronger* attacks not run here (e.g., the LiRA-style attacks of Carlini et al. [3]), but against the two attacks we evaluate, $\varepsilon = 10$ is already operating in the floor regime.
3. The utility cost of DP-SGD is, however, substantial. Test accuracy drops from 60.1% on the overfitted baseline to 43.0% at $\varepsilon = 10$, 39.6% at $\varepsilon = 5$, and 23.6% at $\varepsilon = 1$. The pattern matches Tramèr and Boneh’s observation [5] that DP-SGD’s utility cost grows particularly fast in the low-data regime that we are operating in.

5.4 Aggregate Comparison

Table 2 consolidates the per-experiment numbers for direct comparison. Figures 1, 2, and 3 visualise the generalisation gap, attack AUC, and $TPR@1\%FPR$ across all five configurations, respectively; Figure 4 overlays the empirical ROC curves of the threshold attack on each model.

5.5 Privacy–Utility Trade-off

Figure 5 plots test accuracy versus the actual ε spent at the end of training, with the regularised baseline included as a reference point at conceptual “ $\varepsilon = \infty$ ”. The shape of the curve is consistent with the broader DP-SGD literature: the utility cost is small at large ε (effectively, large ε is “vanilla SGD with extra steps”), grows superlinearly as ε tightens, and falls off a cliff as ε

Table 2: Summary of all five experiments. “Member acc.” for DP configurations is accuracy on the 2,500 target members (a subset of the 15,000 DP training pool); the equivalent for the non-DP rows is the standard train accuracy on `target_train`. “Test acc.” is accuracy on the disjoint `target_test` set. AUC values are for the shadow-model attack (the threshold attack tracks them within ± 0.005 in all configurations).

Configuration	ϵ	Member acc.	Test acc.	Gen. gap	AUC (Shd)	TPR@1%FPR
Exp. 1 — Overfitted	∞	0.996	0.601	0.395	0.788	0.033
Exp. 2 — Regularised	∞	0.886	0.622	0.264	0.664	0.020
Exp. 3 — DP-SGD	10	0.446	0.430	0.016	0.511	0.009
Exp. 4 — DP-SGD	5	0.422	0.396	0.025	0.513	0.007
Exp. 5 — DP-SGD	1	0.244	0.236	0.007	0.511	0.015

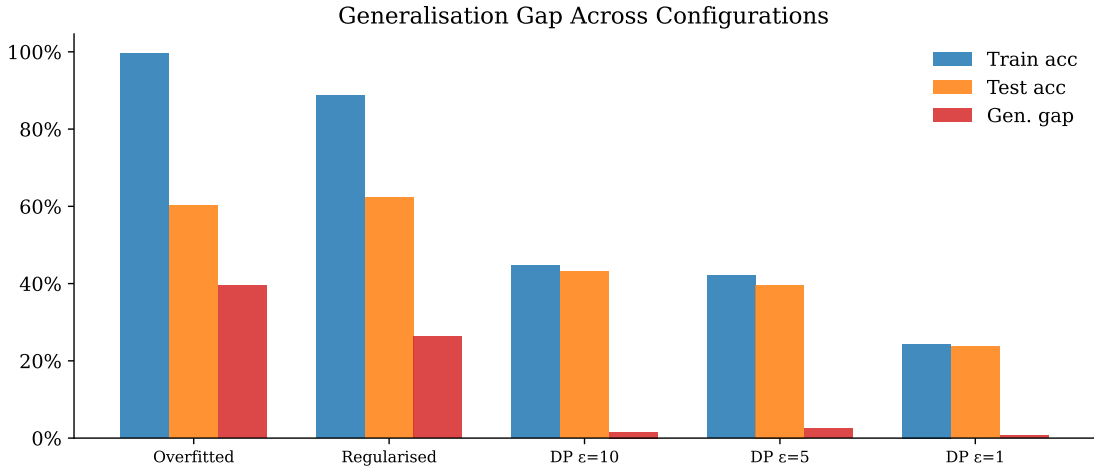


Figure 1: Generalisation gap (train minus test accuracy) across the five configurations. The overfitted target shows a 39.5pp gap; regularisation reduces it to 26.4pp; all three DP-SGD configurations collapse the gap to under 3pp, but at substantially lower absolute accuracy.

approaches one. The TPR@1%FPR curve, in contrast, is essentially flat at the floor across the tested DP range — which is exactly the empirical fingerprint of Differential Privacy doing its job.

The combined message of Figures 2–5 is that, in this setup and against this class of attacks, the *practical* sweet spot is at the looser end of the DP range: $\epsilon = 10$ already pays the structural cost of DP-SGD (loss of representation learning, slower convergence, accuracy ceiling around 43%) without buying additional privacy benefit when one tightens further. A practitioner concerned with stronger attacks (e.g., LiRA) would, of course, want to revisit this conclusion at $\epsilon = 5$ or below.

6 GDPR Analysis

The empirical results of Section 5 are useful only to the extent that they can be brought to bear on the legal questions that motivate the project. This section maps each finding to the GDPR provisions identified in Section 2.3. The mapping is presented as a series of legal-technical claims, each grounded in the empirical results, and each accompanied by an honest statement of its limits.

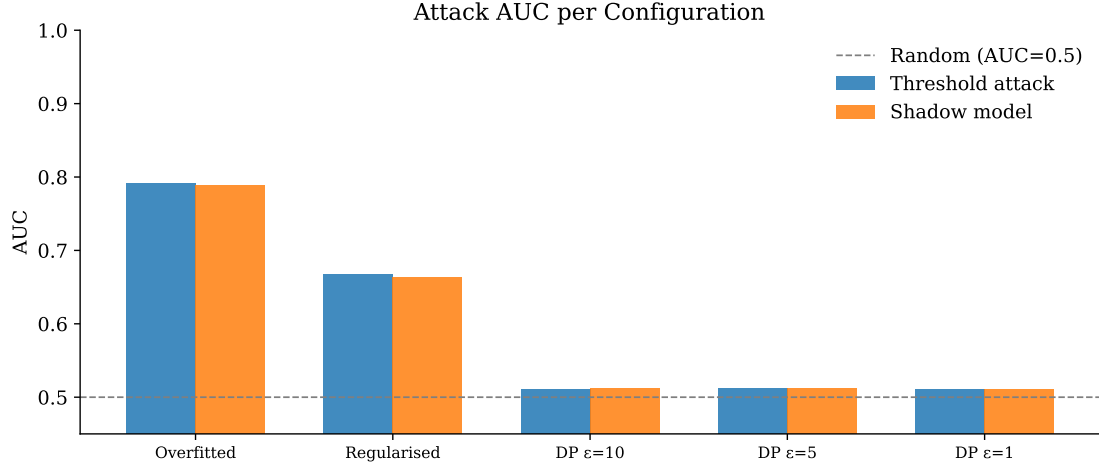


Figure 2: Attack AUC across the five configurations, for both the threshold attack and the shadow-model attack. The dashed line at $\text{AUC} = 0.5$ is the random baseline. DP-SGD pushes both attacks to the random floor at all three privacy budgets.

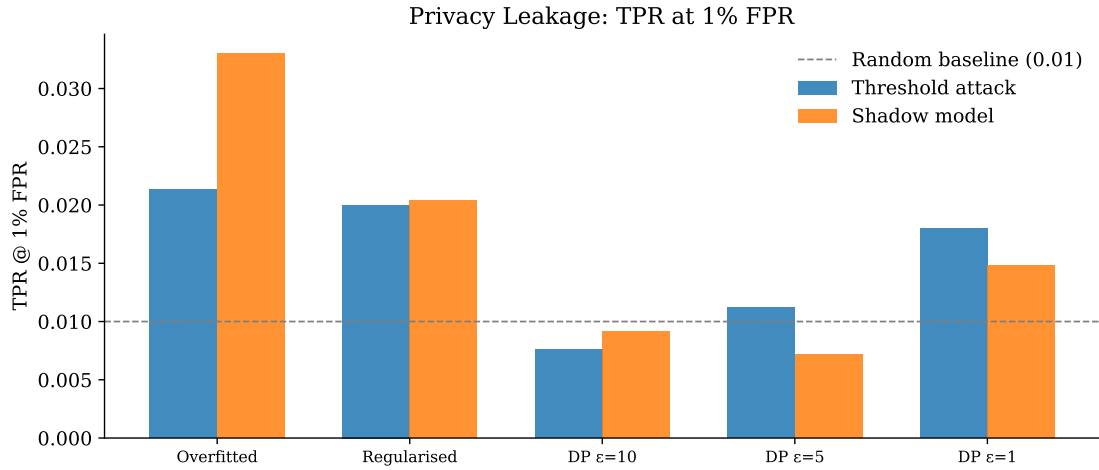


Figure 3: TPR@1%FPR across the five configurations. This is the privacy-relevant low-FPR metric. The dashed line at 0.01 is the random baseline. The shadow-model attack on the overfitted target reaches $\text{TPR@1\%FPR} = 0.033$ — more than three times chance.

6.1 Article 5 — Principles relating to processing

Art. 5(1)(f) — Integrity and confidentiality. Personal data must be processed in a manner that ensures appropriate security, “including protection against unauthorised or unlawful processing”. Our results demonstrate that an ML model trained on personal data *is* a vector for unauthorised disclosure when no privacy defenses are in place: a black-box adversary can determine, with $\text{AUC} \approx 0.79$ on the overfitted target, whether a specific individual’s record was in the training set. This is, on a strict reading, a confidentiality breach mediated by the model itself.

The corresponding compliance question is *quantitative*: at what attack performance does the model stop being a confidentiality breach? The GDPR offers no numerical threshold (and arguably should not), but the reasoning of Art. 32 (“*appropriate* to the risk”) suggests that the answer depends on the sensitivity of the underlying data. For a CIFAR-10 analogue trained on, say, dermatoscopic images of melanoma patients, the residual leak we measure on the regularised

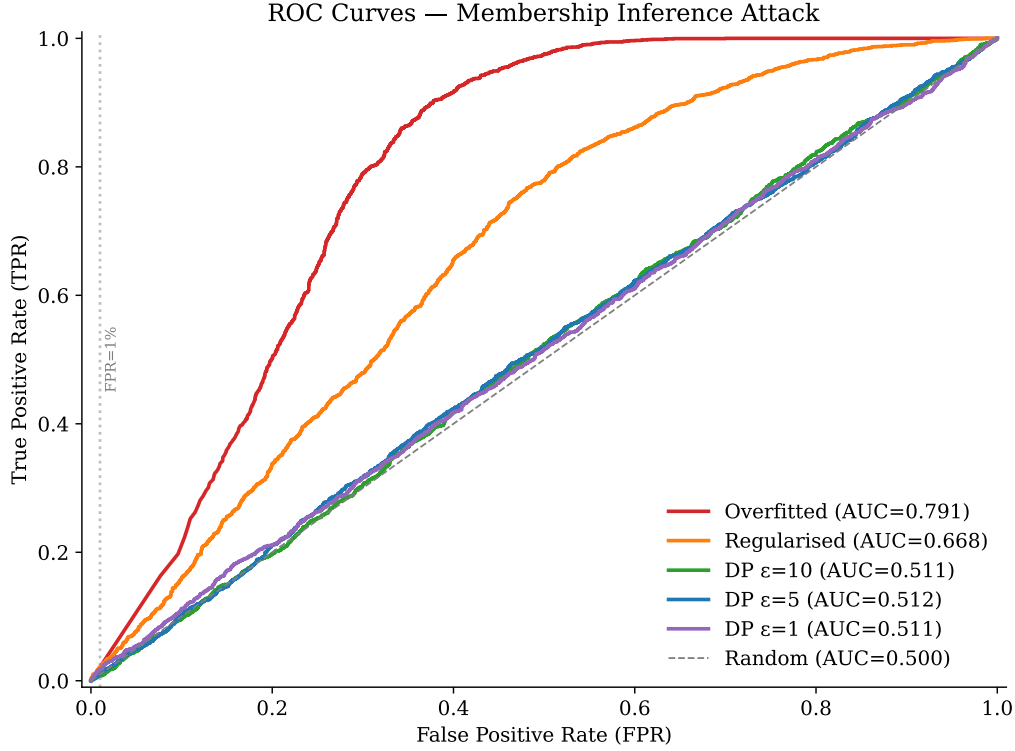


Figure 4: ROC curves of the threshold attack against each of the five target models, on the same set of members and non-members. The dashed diagonal is the random baseline. The overfitted ROC (AUC = 0.79) is well above the diagonal across the entire FPR range; the regularised ROC retains a visible gap; all three DP-SGD ROCs hug the diagonal.

model (AUC = 0.66) is plausibly unacceptable.

Art. 5(1)(c) — Data minimisation. Personal data must be “adequate, relevant and limited to what is necessary” in relation to the purpose. A model that has memorised individual records contains, by construction, more information about those individuals than the classification task strictly required. In this sense, DP-SGD operates as an *algorithmic data-minimisation mechanism*: by clipping per-sample gradients and adding calibrated noise, it provides a mathematical bound on how much information about any single individual can be encoded in the trained weights.

Art. 5(2) — Accountability. Article 5(2) places the burden of demonstrating compliance on the controller. The privacy auditing pipeline described in this report is, in this respect, a direct response to that burden: it produces falsifiable, archived evidence (the AUCs, the TPRs at low FPR, the privacy budgets actually spent) that the controller can attach to a Data Protection Impact Assessment under Art. 35.

6.2 Article 6 — Lawfulness of processing

A valid lawful basis under Art. 6 is necessary but not sufficient for the processing to be lawful in the operational sense: the processing must remain compatible with the purpose declared to data subjects (Art. 5(1)(b)) and, for the legitimate-interest basis (Art. 6(1)(f)), must satisfy a balancing test against the rights of the data subjects.

When MIA reveals that the trained model has memorised individual records, the processing has

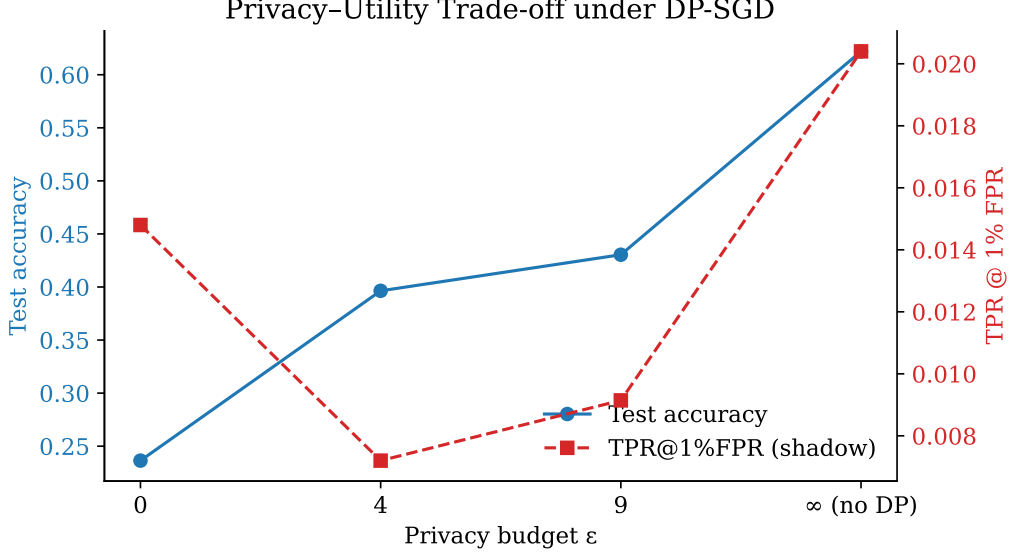


Figure 5: Privacy-utility trade-off under DP-SGD. Test accuracy (left axis, blue circles) drops from 60% on the regularised baseline to 24% at $\epsilon = 1$. The shadow-model TPR@1%FPR (right axis, red squares) is essentially flat at the privacy floor across the tested DP range, confirming that the additional utility cost of moving from $\epsilon = 10$ to $\epsilon = 1$ buys no measurable extra privacy against the attacks evaluated here.

produced an output (the model) whose informational content exceeds what the lawful purpose strictly required. In a balancing test under Art. 6(1)(f), the existence of a practical, mature mitigation (DP-SGD) tilts the balance: a controller who declines to use DP-SGD on the grounds of utility cost is, in effect, asserting that the additional accuracy is more important than the residual privacy risk. Such an assertion may be reasonable, but it is now a position that the controller has to defend, rather than a default that they may assume.

6.3 Article 17 — Right to erasure

The right to erasure is the GDPR provision most clearly in tension with the way machine learning systems are typically deployed. Once a record has been used to train a model, removing it from the underlying database does not remove its *influence on the trained weights*. Our results make this concrete: the overfitted model retains identifiable traces of its training data with AUC = 0.79; the regularised model retains them with AUC = 0.66.

Two operational implications follow:

- **Without DP:** honouring an erasure request rigorously requires retraining the model from scratch on the post-erasure dataset (or invoking a machine-unlearning algorithm, e.g., SISA [10]). For large production models, the cost of doing this on every erasure request is prohibitive, and many controllers do not do it in practice — a quiet violation of Art. 17 that has not yet been the subject of high-profile enforcement action, but which is increasingly visible.
- **With DP-SGD ($\epsilon \leq 10$):** the model’s dependence on any single record is mathematically bounded. The “memory” of each individual is provably limited by the privacy guarantee; the residual inference risk after a record is deleted from the database is correspondingly small. This is not a substitute for genuine retraining if strict erasure is required, but it is a proportionate compromise that materially weakens the residual risk and that has a

Table 3: An illustrative heuristic mapping of shadow-attack AUC to GDPR Art. 5(1)(f) compliance language. The compliance column is **not** a legal opinion; it is a way to make the trade-off visible in the results table.

Configuration	Test acc.	Shadow AUC	Heuristic
Overfitted (no defense)	60.1%	0.788	Clear concern
Regularised (L2 + Dropout + ES)	62.2%	0.664	Clear concern
DP-SGD, $\varepsilon = 10$	43.0%	0.511	Strong compliance
DP-SGD, $\varepsilon = 5$	39.6%	0.513	Strong compliance
DP-SGD, $\varepsilon = 1$	23.6%	0.511	Strong compliance

defensible legal narrative (“the trained weights satisfy (ε, δ) -DP, so the contribution of any single record is bounded by Equation 1”).

6.4 Article 32 — Security of processing

Article 32 requires “appropriate technical and organisational measures” proportionate to the risk, with explicit reference to the “state of the art”. The empirical results of Section 5 give a measurable operationalisation of “appropriate” for ML systems trained on personal data:

1. Regularisation alone is *insufficient*: the attack retains $\text{AUC} = 0.66$ on the regularised target, well above the random baseline.
2. DP-SGD with $\varepsilon \leq 10$ brings attack success to the privacy floor ($\text{AUC} \approx 0.51$). This is, in our view, a credible candidate for “appropriate” under Art. 32 for most personal-data classification tasks.
3. The utility cost (between 17pp at $\varepsilon = 10$ and 36pp at $\varepsilon = 1$) must be weighed against the sensitivity of the data. For Art. 9 special categories, the utility cost is easier to justify; for ordinary personal data with low downstream risk, it may be disproportionate.

A heuristic mapping of the shadow-attack AUC to compliance language is given in Table 3. It is illustrative only: the actual “appropriate” threshold depends on the data, the controller, and the regulator, and is not something a Python script should be allowed to decide.

7 Discussion

7.1 Findings, restated

Three of the project’s findings are robust enough to be stated without qualification:

- *MIA is empirically practical* on overfitted CNN classifiers in the small-data regime. With 2,500 training samples and an unregularised CNN, both a simple loss-threshold attack and a shadow-model attack achieve $\text{AUC} \approx 0.79$ — well above the random baseline of 0.5.
- *Regularisation is a defense for generalisation, not for privacy*. L2 weight decay, dropout, and early stopping, applied together, reduce the attack’s AUC from 0.79 to 0.66. The reduction is real but partial; a model with $\text{AUC} = 0.66$ is still leaking information that a determined adversary can exploit, and this matches the discussion in Yeom et al. [2].

- *DP-SGD effectively neutralises the attacks tested here*, at all three privacy budgets, but at substantial utility cost. The cost is concentrated in the first “unit” of ϵ tightening: dropping from $\epsilon = \infty$ to $\epsilon = 10$ costs roughly 17pp of test accuracy; dropping from $\epsilon = 10$ to $\epsilon = 5$ costs roughly 3pp more; dropping from $\epsilon = 5$ to $\epsilon = 1$ costs another 16pp. The privacy gain on the attacks evaluated here, in contrast, is essentially zero across this range.

7.2 Practitioner Recommendations

The findings suggest the following practitioner guidelines for ML systems trained on personal data:

1. **Audit MIA before deployment.** Generalisation gap on a held-out set is not, by itself, a sufficient privacy indicator. A direct MIA evaluation — of the kind whose pipeline is described in Section 3 — should be a routine part of the pre-deployment checklist for any ML system trained on personal data.
2. **Do not rely on regularisation as a privacy defense.** Regularisation reduces leakage as a side effect, but it is not designed for privacy and provides no formal guarantee. The legal narrative “we used L2 and dropout, therefore the model is GDPR-compliant” is empirically unsupported.
3. **Use DP-SGD as the formal-guarantee defense.** For most personal-data classification tasks, ϵ in the range $[5, 10]$ is a defensible operating point: it provides a meaningful technical safeguard under Art. 32 while keeping utility within an order of magnitude of the unregularised baseline.
4. **Reserve $\epsilon = 1$ for the most sensitive data.** Special categories under Art. 9, or contexts where the data subject’s risk is high enough that utility loss is acceptable. For ordinary personal data with low downstream risk, $\epsilon = 1$ is an over-engineered choice that sacrifices utility without buying additional protection against the attacks tested here.
5. **Increase the training set size when possible.** The utility cost of DP-SGD scales *much* better with data size than with ϵ . Larger training sets are the single most effective lever a practitioner has against the privacy/utility trade-off.
6. **Document the privacy budget alongside the model.** The actual ϵ spent at the end of training (as reported by the privacy accountant) should be archived as part of the model’s metadata, in the same way that the architecture and the training-data hash are. This is the form of evidence that Art. 5(2) (*accountability*) calls for.

7.3 What “compliance” does and does not mean here

A point that deserves emphasis is that no choice of ϵ *automatically* renders an ML system GDPR-compliant. Compliance is a property of the entire processing operation — including the lawful basis, the purpose declaration, the data-subject information, the data-protection-by-design considerations, the DPIA where required — not a property of any single technical measure. DP-SGD is a powerful and increasingly mature ingredient of compliance, but it is not a substitute for the rest of the compliance workflow. The contribution of empirical privacy auditing of the kind described in this report is to render the *technical* dimension of compliance *measurable*, so

that the controller’s accountability obligation under Art. 5(2) can be discharged with evidence rather than with assertion.

8 Limitations and Future Work

The project’s scope was deliberately restricted to keep the empirical work tractable. Several limitations follow, and each suggests a natural extension.

Single benchmark dataset. All experiments were performed on CIFAR-10. A natural extension is to repeat the pipeline on a benchmark with genuinely sensitive content — CheXpert chest X-rays [11] or a face-recognition dataset would be the canonical candidates — to verify that the privacy/utility curve has the same shape on data where the GDPR connection is not just analogical.

Two attack strategies. The threshold and shadow-model attacks are foundational but not the strongest available. The likelihood-ratio attack of Carlini et al. [3] (LiRA) is known to push TPR@0.1%FPR substantially higher on similar benchmarks. A LiRA evaluation would test whether DP-SGD at $\varepsilon = 10$ remains in the privacy-floor regime against stronger attacks; the hypothesis is that some loss of margin would be visible at lower FPR thresholds.

Single architecture. A small CNN was used throughout. The behaviour of MIA and DP-SGD on larger architectures (e.g., ResNet-18, ViT-Tiny) is qualitatively similar in the literature but quantitatively different: larger models have more parameters, can memorise more, and pay a larger DP-SGD utility cost. A small extension would be to repeat Experiments 1, 2, and 3 on a ResNet-18.

Hyper-parameter sensitivity. The DP-SGD experiments use default-ish hyper-parameters ($C = 1.2$, learning rate 2×10^{-3} , 60 epochs). DP-SGD is known to be sensitive to these choices; a hyper-parameter sweep would refine the privacy/utility curve and might recover some of the utility cost [5].

Hardware and infrastructure. Training was performed on Google Colab; the runtime budget effectively caps the experiments at about three hours per full sweep. A larger compute budget would enable, in particular, a denser DP-SGD sweep ($\varepsilon \in \{0.5, 1, 2, 3, 5, 10, 20\}$) and a multi-seed analysis to bound the noise of the reported AUCs.

9 Conclusions

This project set out to do two things: build a working, reproducible privacy-auditing pipeline for ML classifiers, and use it to interrogate what the GDPR’s risk-based standard for “appropriate technical measures” should mean in concrete terms for the kind of system that an ML practitioner actually deploys. On both counts, the results are clearer than I expected when I started the project.

On the technical side: Membership Inference Attacks are practical, they are empirically reproducible on a laptop GPU in a few hours, and standard ML hygiene is not enough to defeat them.

DP-SGD, in contrast, is enough to defeat them — across the full range of privacy budgets we tested — but only at a cost that, in the small-data regime, is hard to ignore.

On the normative side: it is meaningful and useful to talk about GDPR compliance for ML systems in *measurable* terms. “*Appropriate*” under Art. 32 is, by design, a moving target; empirical privacy auditing turns that target into a number that the controller can either justify or change. The most important contribution of this kind of work is not, in my view, the specific ε thresholds it suggests, but the methodological habit it encourages: *do not assert that the model is privacy-safe, measure that it is*.

References

- [1] R. Shokri, M. Stronati, C. Song, and V. Shmatikov. Membership inference attacks against machine learning models. In *IEEE Symposium on Security and Privacy (S&P)*, 2017.
- [2] S. Yeom, I. Giacomelli, M. Fredrikson, and S. Jha. Privacy risk in machine learning: Analyzing the connection to overfitting. In *IEEE Computer Security Foundations Symposium (CSF)*, 2018.
- [3] N. Carlini, S. Chien, M. Nasr, S. Song, A. Terzis, and F. Tramèr. Membership inference attacks from first principles. In *IEEE Symposium on Security and Privacy (S&P)*, 2022.
- [4] M. Abadi, A. Chu, I. Goodfellow, H. B. McMahan, I. Mironov, K. Talwar, and L. Zhang. Deep learning with differential privacy. In *ACM Conference on Computer and Communications Security (CCS)*, 2016.
- [5] F. Tramèr and D. Boneh. Differentially private learning needs better features (or much more data). In *International Conference on Learning Representations (ICLR)*, 2021.
- [6] C. Dwork and A. Roth. The algorithmic foundations of differential privacy. *Foundations and Trends in Theoretical Computer Science*, 9(3–4):211–407, 2014.
- [7] I. Mironov. Rényi differential privacy. In *IEEE Computer Security Foundations Symposium (CSF)*, 2017.
- [8] A. Krizhevsky. Learning multiple layers of features from tiny images. Technical Report, University of Toronto, 2009.
- [9] A. Yousefpour, I. Shilov, A. Sablayrolles, D. Testuggine, K. Prasad, M. Malek, J. Nguyen, S. Ghosh, A. Bharadwaj, J. Zhao, G. Cormode, and I. Mironov. Opacus: User-friendly differential privacy library in PyTorch. *arXiv preprint arXiv:2109.12298*, 2021.
- [10] L. Bourtole, V. Chandrasekaran, C. A. Choquette-Choo, H. Jia, A. Travers, B. Zhang, D. Lie, and N. Papernot. Machine unlearning. In *IEEE Symposium on Security and Privacy (S&P)*, 2021.
- [11] J. Irvin et al. CheXpert: A large chest radiograph dataset with uncertainty labels and expert comparison. In *AAAI Conference on Artificial Intelligence*, 2019.
- [12] European Parliament and Council of the European Union. Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such

data (General Data Protection Regulation). *Official Journal of the European Union*, L 119/1, 2016.